

STATEMENT OF WORK (SOW)

API Security Assessment (VAPT) and Load Testing

Prepared by: Pitowings Private Limited

1. OBJECTIVE

The objective of this engagement is to perform a comprehensive Vulnerability Assessment and Penetration Testing (VAPT) and Load Testing of the client's API-based application.

The assessment aims to:

- Identify security vulnerabilities
- Validate existing security controls
- Assess system performance under load
- Provide actionable remediation recommendations

All activities will be conducted in alignment with CERT-In expectations, OWASP standards, and globally accepted security testing methodologies.

2. COMPLIANCE & STANDARDS ALIGNMENT

This assessment will adhere to the following standards:

- CERT-In Guidelines for Security Auditing of IT Infrastructure
- OWASP API Security Top 10
- OWASP Testing Guide (v4)
- ISO/IEC 27001:2022 (Relevant Controls)
- NIST SP 800-115

All identified vulnerabilities will be evaluated using the CVSS v3.1 scoring framework.

3. SCOPE OF WORK

3.1 API Security Testing (VAPT)

- Assessment of approximately 25 API endpoints (5 GET methods and 20 POST methods)

Coverage includes:

- Authentication and authorization mechanisms
- Input validation (Injection, XSS, etc.)
- Business logic vulnerabilities
- API abuse scenarios and rate limiting
- Sensitive data exposure
- Security misconfigurations

Testing will involve a combination of automated tools and manual validation techniques.

3.2 Load / Performance Testing

- Simulation of concurrent users to evaluate:
 - Response time
 - Throughput
 - Error rates
 - System stability under load

4. METHODOLOGY

The engagement will follow a structured approach:

1. Information Gathering
2. Threat Modeling
3. Vulnerability Identification
4. Exploitation & Validation
5. Risk Analysis (CVSS Scoring)
6. Reporting
7. Re-Validation

5. ENGAGEMENT APPROACH

5.1 Scope Optimization

- Similar endpoints will be grouped and tested as representative samples
- Focus will be on unique functional flows and attack vectors

5.2 Client Responsibilities

The client shall provide:

- API documentation (Swagger/OpenAPI/Postman Collection)
- Access to staging/test environment
- Valid test credentials
- Preloaded test data

5.3 Re-Validation

- One round of re-testing (fix verification) is included
- Ensures proper closure of identified vulnerabilities

6. DELIVERABLES

Reports

- Detailed VAPT Report (CVSS scoring, PoC, remediation)
- Executive Summary Report
- Load Testing Report
- Re-Validation Report

Executive Attestation of Security Testing (Included)

A one-page formal certificate confirming that:

- APIs were assessed against OWASP standards and industry best practices
- Testing followed recognized security methodologies
- Overall security posture summary is provided

This certificate can be shared with stakeholders, partners, and investors without exposing detailed vulnerabilities.

7. TIMELINE

Phase	Duration
VAPT Execution	4 - 5 Working Days
Load Testing	2 Working Days
Reporting	2 Working Days
Re-Validation	1 - 2 Working Days

Total Duration: 7 - 10 Working Days

Important Note:

Timeline will commence only after receiving all prerequisites, including environment access, credentials, and documentation.

8. COMMERCIALS

Particulars	Amount
Base Cost (Excluding GST)	₹1,35,000 (Rupees One Lakh Thirty-Five Thousand Only)
GST (18%)	₹24,300
Total Cost (Including GST)	₹1,59,300 (Rupees One Lakh Fifty-Nine Thousand Three Hundred Only)

Payment Terms

Milestone	Amount
60% Advance (Project Initiation)	₹81,000 + GST
40% Upon Submission of Final Report	₹54,000 + GST

Notes

- Invoices will be raised as per milestone completion
- One re-validation cycle is included
- Additional re-testing cycles will be charged separately

9. ASSUMPTIONS

- Testing will be conducted in a controlled staging environment
- APIs remain stable and accessible during testing
- Scope limited to 25 endpoints (with logical grouping applied)

10. EXCLUSIONS

- Source code review
- Cloud infrastructure security audit
- Mobile application security testing
- Fixing of vulnerabilities / code-level remediation (Only recommendations will be provided; implementation is client's responsibility)

11. CONFIDENTIALITY & DATA PROTECTION

- All information will be treated as strictly confidential
- Engagement will follow ISO 27001 data handling principles
- No sensitive data will be retained post-engagement

12. LEGAL & COMPLIANCE

- Testing will be conducted with formal authorization
- All activities comply with Indian IT Act 2000 and CERT-In directives

- No disruptive testing will be performed without approval

13. ACCEPTANCE

By proceeding with this engagement, both parties agree to the scope, methodology, timeline, and commercials outlined in this document.

For Pitowings Private Limited

Name: _____

Designation: _____

Signature: _____

For

Name: _____

Designation: _____

Signature: _____